PRIVILEGED ACCESS MANAGEMENT POLICY

POL-009 | Issued under the Information Management Framework

Document ID: POL-009
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Sensitive
Owner: Chief Information Security Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Privileged Access Management Policy
Document ID	POL-009
Version	1.0 — DRAFT
Status	Draft for Review
Classification	Sensitive — restricted to CISO, CIO, Information Security, Compliance / QA, and designated System Owners
Parent Framework	IMF-001 — Information Management Framework
Parent Policy	POL-008 — Access Control Policy
Document Owner	Chief Information Security Officer (CISO)
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	21 CFR Part 11, EU Annex 11, SOX (ITGC), HIPAA Security Rule, ISO/IEC 27001:2022 (A.5.18, A.8.2), CIS Controls v8 (Control 5), NIST SP 800-53 (AC-2, AC-6, AC-17)

IMPORTANT: This document is classified Sensitive. Its contents — including the list of privileged account types, PAM tooling, and break-glass procedures — must not be shared beyond the roles listed above. Distribution by email is prohibited. Access this document only through the approved document management system.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

Privileged access is the greatest single source of systemic risk in any IT environment. A privileged account — one with administrative, root, superuser, or system-level permissions — can bypass normal access controls, disable audit trails, delete or modify records at scale, and act across multiple systems simultaneously. The compromise or misuse of a privileged account is therefore qualitatively different from the compromise of a standard user account.

This Policy establishes mandatory controls for all privileged identities at [Company Name] — human administrators, service accounts, system accounts, and API credentials with elevated permissions. It supplements POL-008 (Access Control Policy), which governs standard user access. Where this Policy imposes more stringent requirements than POL-008, this Policy takes precedence.

For GxP-validated systems (Track A per POL-006): privileged access controls are additionally a regulatory concern. Any privileged action on a GxP system — including changes to audit trail configuration, user access settings, or system configuration — is a change event under POL-007 and must be managed accordingly. Uncontrolled privileged access to a GxP system can compromise the validated state of that system and trigger re-validation obligations.

> **NOTE:** This Policy applies to all privileged accounts — not only IT administrators. A laboratory scientist with administrative access to a LIMS is a privileged user for the purposes of this Policy. A finance manager with system administrator rights in the ERP is a privileged user. Privileged status is determined by the permissions held, not by job title.

2. Scope

This Policy applies to all privileged identities and all systems classified under POL-005. The scope includes:

- Human privileged users: IT administrators, system administrators, database administrators, network administrators, security administrators, and any end-user granted administrative rights on a system
- Service accounts: non-human accounts used by applications, automated processes, or integrations to access systems, databases, or APIs
- System accounts: built-in operating system or application accounts (e.g., root, Administrator, sa) with elevated permissions
- Emergency / break-glass accounts: accounts held in reserve for use only when normal privileged access mechanisms fail
- Third-party privileged accounts: vendor or consultant accounts with administrative access to any [Company Name] system

The controls in this Policy scale with the criticality tier and regulatory flags of the systems being accessed. Section 5 defines the specific requirements per tier. The most stringent controls apply to Tier 1 systems and all GxP-flagged and SOX-scoped systems.

3. Core Principles for Privileged Access

Principle	Requirement
Separation of Privileged and Standard Accounts	Human users who hold both standard and privileged access must use separate accounts for standard work and privileged tasks. Privileged accounts must not be used for email, web browsing, or any non-administrative activity. Separate account naming convention required (e.g., [username]-admin).
Just-in-Time (JIT) Access	Privileged access to Tier 1 production systems is not persistent. It is activated for a specific session, for a specific purpose, for a defined time window, and automatically expires at the end of the window. JIT access reduces the standing attack surface — a compromised credential that is not active cannot be used.
Just-Enough Access	Privileged accounts carry only the permissions required for the specific administrative function. A database administrator does not receive operating system administrative rights. An application administrator does not receive database administrator rights unless both are required for their specific function.
No Standing Privileged Access to Production GxP Systems	Privileged access to production GxP systems must be activated through the PAM platform for each session. No human privileged account may have persistent, always-on access to a GxP production system. This prevents undetected privileged activity between sessions and supports audit trail completeness.
All Privileged Sessions Are Logged	Every privileged session — on every system at every tier — must generate an audit log entry recording the account used, the system accessed, the start time, the end time, and where technically feasible, the commands or actions executed.
No Privileged Sharing	Privileged accounts are never shared. Each privileged account is assigned to a single named individual (for human accounts) or a single defined process (for service accounts). This applies without exception across all tiers.

4. Privileged Account Inventory

Information Security maintains a Privileged Account Inventory — the authoritative register of all privileged accounts across all in-scope systems. The Inventory must be accurate, current, and used as the basis for privileged access reviews.

Inventory Field	Description
Account name / ID	The account identifier in the target system
Account type	Human (administrator), service account, system account, break-glass, or third-party
System(s) accessed	All systems on which this account holds privileged access, with POL-005 tier and regulatory flags
Account owner	For human accounts: the named individual. For service accounts: the owning application/process and the responsible System Owner. For third-party accounts: vendor name and internal Sponsor.
Privilege level	The specific permissions held (e.g., OS admin, DB admin, application admin, specific elevated role)
Access type	Persistent, JIT, or break-glass
Last access date	Date and time of last login (from audit log or PAM platform)
Review date	Date of last privileged access review
Justification	Business justification for the privileged access

The Inventory is reviewed and reconciled against each system's actual privileged account list at least quarterly for Tier 1 and GxP/SOX systems, and at least semi-annually for Tier 2/3 systems. Accounts discovered in a system that are not in the Inventory are treated as unauthorised and immediately investigated.

5. Privileged Access Requirements by System Tier

The following requirements apply based on the primary system's POL-005 classification. Where a system carries both a criticality tier and a regulatory flag, the most stringent applicable row governs.

Requirement	Tier 1 / GxP-Flagged	Tier 2 (incl. SOX)	Tier 3	Tier 4
Separate admin account required	Mandatory	Mandatory	Mandatory	Recommen ded

Requirement	Tier 1 / GxP-Flagged	Tier 2 (incl. SOX)	Tier 3	Tier 4
MFA method for privileged access	Hardware security key (FIDO2) required	FIDO2 or TOTP authenticator	TOTP authenticator	Any approved MFA
JIT access (no persistent standing privileged access)	Mandatory via PAM platform	Mandatory via PAM platform	Recommended; persistent permitted with quarterly review	Not required
Session recording	Mandatory — all sessions recorded and retained 1 year	Mandatory for SOX-scoped; recommended others	Recommended	Not required
Privileged access review frequency	Monthly	Quarterly	Semi-annual	Annual
PAM platform required	Mandatory	Mandatory	Recommended	Not required
Dual approval for critical changes (e.g., audit trail config)	Mandatory — two named privileged users must approve	Required for SOX ITGC-affecting changes	Not required	Not required
Third-party privileged sessions	Session recording mandatory; sessions supervised or time-boxed to 4 hours maximum	Session recording mandatory	Monitoring required	Standard third-party access controls
Change management requirement (POL-007)	All privileged actions that modify system configuration, audit trail settings, or user access require a POL-007 change record	Changes affecting ITGC controls require POL-007 record	Normal changes only	Standard

IMPORTANT: For GxP systems: any privileged action that modifies audit trail configuration, access control settings, or system configuration parameters is a change under POL-007 — regardless of how minor it appears. There is no 'quick fix' exception for GxP systems. The change record is what allows the action to be traced in an audit trail review (SOP-003) and explained to an inspector.

6. Service Account Management

Service accounts represent one of the most frequently exploited categories of privileged identity. They are often overprivileged (granted broad access for convenience), undermanaged (no owner accountable for them), and long-lived (credentials rarely rotated). This Policy imposes specific controls to address each of these risks.

Control	Requirement
One purpose per service account	Each service account must serve a single, defined application or process. Service accounts must not be reused across applications. If an application is retired, its service account must be deleted.
Documented ownership	Every service account must have a named System Owner who is accountable for its permissions, credential rotation, and decommissioning. Ownerless service accounts must not exist. If a service account's owner leaves, a new owner must be assigned within 5 business days.
Least privilege for service accounts	Service accounts must be granted only the permissions required for the specific process they serve. Service accounts must not be granted domain administrator, enterprise administrator, or equivalent global administrator permissions unless no alternative is technically feasible — and only with CISO approval and compensating controls.
No interactive login for service accounts	Service accounts must be configured to prevent interactive login (keyboard-based login at a terminal). If a service account is found to have been used for interactive login, this is treated as a security incident per POL-012.
Credential management	Service account credentials (passwords, API keys, certificates) must be stored in the approved PAM platform or secrets management system — not hardcoded in scripts, configuration files, or source code. Credentials must be rotated at least annually for Tier 3/4 systems, every 90 days for Tier 2, and every 90 days or on each use (JIT credential issue) for Tier 1 and GxP systems.
Service account review	Service accounts are included in the privileged access review cadence per Section 5. For each review, the System Owner confirms: the account is still needed; the credentials are rotated per schedule; the permissions remain appropriate; and no interactive logins have occurred since the last review.
Decommissioning	When an application or integration is decommissioned, its service account(s) must be disabled within 24 hours and deleted within 30 days. Credentials for decommissioned service accounts must be revoked immediately.

6.1 API Keys and Tokens

API keys, bearer tokens, and OAuth credentials used to access systems with elevated permissions are governed as service accounts under this Policy. The following additional controls apply:

- API keys with privileged access must be stored exclusively in the approved secrets management platform — never in environment variables, CI/CD pipeline configuration, or source code repositories
- API keys must be scoped to the minimum permissions required for the specific integration
- API keys must have an expiry date not exceeding 12 months for Tier 1/2 and GxP systems, and 24 months for Tier 3/4
- All API calls from privileged API keys must be logged and includable in access review and audit trail analysis
- Discovery of an API key stored outside the approved secrets management platform is a security incident per POL-012

7. Emergency (Break-Glass) Access

Break-glass accounts are reserved for use only when normal privileged access mechanisms are unavailable — typically during a major incident where the PAM platform itself or the identity provider is unavailable. They represent a controlled safety valve, not an alternative to the normal PAM process.

7.1 Break-Glass Account Configuration

- Each Tier 1 system and each GxP-flagged system must have at least one break-glass account documented in the Privileged Account Inventory
- Break-glass credentials are stored in a physical sealed envelope in a controlled, access-logged physical location (e.g., the CISO's safe or an equivalent security-controlled cabinet). Electronic storage of break-glass credentials in any online system defeats their purpose.
- Break-glass account credentials must be unique, complex, and rotated immediately after any use and at least annually regardless of use
- Break-glass accounts must have the minimum permissions required to restore normal operations — they are not all-powerful superuser accounts

7.2 Break-Glass Usage Process

Step 01	**Obtain CISO Authorisation** Before the sealed envelope is opened, verbal or written authorisation must be obtained from the CISO (or designated deputy). The authorisation must include: the reason for break-glass access, the system(s) to be accessed, and the named individual who will use the account. Authorisation is logged immediately.	Responsible **Requesting engineer / CISO**
Step 02	**Open Sealed Envelope Under Witness** The sealed envelope is opened by the authorised user in the presence of a second named witness (Information Security or another senior IT staff member). The opening is recorded: date, time, opener, witness. The envelope seal breach itself is the evidence of use — the physical record is important.	Responsible **Authorised user / Witness**
Step 03	**Execute with Minimum Actions** The break-glass user performs only the actions necessary to resolve the immediate emergency. All actions must be documented in real time (date, time, system, action taken). For GxP systems: the actions constitute a POL-007 emergency change and must be documented retrospectively as such within 4 hours.	Responsible **Authorised user**

Step 04	**Rotate Credentials Immediately** As soon as the emergency is resolved, the break-glass credentials are changed. A new sealed envelope is prepared and placed in the controlled location. The Privileged Account Inventory is updated with the rotation date. The used credential is permanently retired.	Responsible **Information Security**
Step 05	**Post-Use Review** Within 48 hours of break-glass use: CISO reviews the session log and all actions taken. For GxP systems: Compliance / QA reviews the actions for impact on validated state. For any system: a root-cause assessment of why normal access was unavailable must be documented and any resilience gaps addressed. All break-glass uses are reported at the next ISSG meeting regardless of tier.	Responsible **CISO / Compliance / QA (GxP)**

IMPORTANT: Break-glass access must never be used as a workaround for normal change management, as a way to avoid the JIT access process, or as a convenience mechanism. Each use is an exceptional event and is treated as such. Patterns of break-glass usage indicate a failure in normal privileged access controls and will be investigated.

8. Third-Party Privileged Access

Third-party vendors and consultants occasionally require privileged access for installation, maintenance, upgrade, or troubleshooting activities. This access carries the same risks as internal privileged access and is subject to equivalently stringent controls.

Control	Requirement
Named individual accounts only	Third-party privileged accounts are issued to named individuals — not to 'Vendor X Admin'. Each individual from a third party with privileged access has their own account. Shared vendor privileged accounts are prohibited on all tiers.
Time-limited activation	Third-party privileged access is activated for a specific maintenance window only. Access is not persistent. The session begins and ends within the agreed window. If the work is not completed within the window, a new access request and approval are required.
Session supervision (Tier 1 / GxP)	For Tier 1 and all GxP-flagged systems: a named [Company Name] employee must be present (physically or via screen-share) during any third-party privileged session. Third-party vendors must not be left unattended with privileged access to these systems. Session recording is also mandatory per Section 5.
GxP change record requirement	Any third-party privileged action on a GxP system that modifies configuration, audit trail settings, or user access is a change under POL-007 and requires a change record. The vendor must provide a record of actions taken; [Company Name] Compliance / QA reviews these records as part of the change close-out.
Credential revocation on completion	Third-party privileged credentials are revoked at the end of the engagement, not at the end of the contract. If a vendor's engineer changes, the previous engineer's access is revoked within 24 hours.
Pre-access documentation	Before any third-party privileged access session: the purpose, scope, and expected actions must be documented. For GxP systems: this documentation forms part of the POL-007 change record. For SOX systems: it contributes to ITGC change management evidence.

9. Privileged Access Reviews

Privileged access reviews are separate from and in addition to the standard access reviews under POL-008. They are conducted at higher frequency, with deeper scrutiny, and with CISO oversight.

Review Component	Frequency	Reviewer	Required Evidence
Human privileged accounts	Monthly	Information	Account list from PAM platform or

Review Component	Frequency	Reviewer	Required Evidence
(Tier 1 / GxP / SOX)		Security + CISO	system. Confirm each account is still needed, still assigned to the right individual, and credentials are current. Session log summary reviewed for anomalies.
Human privileged accounts (Tier 2, non-SOX)	Quarterly	Information Security	Account list. Confirm continued business need. Any inactive accounts (no sessions in past 90 days) queried with System Owner.
Human privileged accounts (Tier 3)	Semi-annual	Information Security	Account list. Confirm continued business need.
Service accounts (all tiers)	Quarterly	System Owner + Information Security	Service account inventory confirmed against system. Confirm owner, purpose, credential rotation date, last access date. Ownerless accounts investigated immediately.
Break-glass accounts (all tiers)	Semi-annual	CISO	Confirm sealed envelopes are intact (or recently rotated if used). Confirm credentials are current. Confirm access level is minimum necessary.
Third-party privileged accounts	Monthly for active engagements ; immediately on engagement end	Information Security / Sponsor	Confirm all active third-party privileged accounts are for current, active engagements. Revoke any for completed engagements.

Review records must be documented and retained for 3 years for non-GxP/non-SOX systems, 7 years for SOX-scoped systems, and per the applicable GxP retention period for GxP systems. SOX ITGC privileged access review evidence is produced for annual SOX testing.

10. Privileged Access Monitoring and Alerting

Privileged activity must be monitored in near real-time for Tier 1 and GxP/SOX systems. Information Security defines and maintains a set of alert conditions that indicate potential misuse or compromise of privileged accounts:

Alert Condition	Response
Privileged access outside approved business hours or approved maintenance window	Immediate alert to CISO and relevant System Owner. Session reviewed within 1 hour.
Failed privileged login attempts (≥3 consecutive)	Account locked. CISO notified. Event investigated within 4 hours.
Privileged access to a GxP system outside a logged change event or approved maintenance window	Treated as a potential POL-007 and SOP-003 violation. System Owner and Compliance / QA notified immediately. Session recorded reviewed.
Service account used for interactive login	Treated as security incident per POL-012. Account suspended. Investigated within 4 hours.
Break-glass account accessed	CISO notified immediately regardless of whether pre-authorisation was obtained. Review initiated per Section 7.2 Step 5.
Privileged session duration exceeds approved window	Session terminated if technically feasible. CISO and System Owner notified.
Audit trail configuration change on any Tier 1 or GxP system	Treated as Critical priority event. DIO and Compliance / QA notified immediately. POL-007 change record and SOP-003 incident review initiated.

11. Roles and Responsibilities

Role	Responsibility
CISO	Policy owner. Authorises break-glass use. Approves exceptions. Reviews monthly privileged access review results. Receives all critical PAM alerts. Approves new privileged account types.
Information Security	Manages PAM platform. Maintains Privileged Account Inventory. Executes privileged access reviews. Monitors privileged session alerts. Revokes privileged access on departure.
System Owner	Reviews service accounts for their systems. Confirms continued business need for privileged accounts on their systems. Documents all privileged actions taken during maintenance.
Compliance / QA	Reviews privileged access events on GxP systems for impact on validated state and audit trail completeness. Receives break-glass use notifications for GxP systems. Confirms POL-007 change records for GxP privileged actions.
Data Custodian (IT)	Holds privileged access to implement technical changes. Uses only JIT access on Tier 1 and GxP systems. Documents all actions during privileged sessions.
All Privileged Users	Use privileged accounts only for authorised administrative tasks. Never share privileged credentials. Report any suspected compromise of

Role	Responsibility
	privileged credentials immediately to CISO. Complete mandatory PAM training annually.

12. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework
POL-008	Access Control Policy	Parent policy for all access control — this Policy supplements POL-008 for privileged identities
POL-003	Data Integrity Policy	Privileged access to GxP audit trail configuration is the highest-risk vector for data integrity compromise; this Policy directly mitigates that risk
POL-005	System Classification Policy	System criticality tier and regulatory flags determine the privileged access controls required under Section 5
POL-006	Computer System Validation and Qualification Policy	Privileged access controls for GxP systems must be captured in URS and tested in OQ; this Policy defines those controls
POL-007	Change Management Policy	All privileged actions on GxP systems that modify configuration, audit trail, or access settings are POL-007 change events
POL-010	Information Security Risk Policy	Compromised privileged accounts are Critical IS risks per POL-010; the PAM controls in this Policy are primary mitigations for the IS Operational risk category; break-glass usage patterns are IS risk signals tracked in the Risk Register
POL-012	Incident Response Policy	Compromised privileged accounts, break-glass misuse, and service account interactive login events are security incidents per POL-012
POL-014	Audit Trail and Monitoring Policy	Privileged session events are the highest-risk audit trail category; session recording complements the event-level audit trail; privileged access review evidence is sourced from POL-014 audit trail records; PAM alerts feed the SIEM monitoring programme
POL-013	Third Party and Vendor Risk Policy	Third-party privileged access requirements in Section 8; vendor session supervision and

Document ID	Title	Relationship
		POL-007 change record obligations
SOP-003	Data Integrity Process	Audit trail review (SOP-003 Section 7) includes review of privileged access events; alerts from Section 10 may trigger SOP-003 incident process
EXC-001	Exception Management Policy and Register	Privileged access exceptions are high-risk — exceptions to PAM session recording for Tier 1/GxP systems require CISO approval and real-time session supervision as compensating controls; 3-month maximum duration per EXC-001
RACI-001	Roles, Responsibilities and Authorities	PAM accountability mapping

13. Definitions

Term	Definition
Break-Glass Account	A reserved account stored offline for use only when normal privileged access mechanisms are unavailable. Each use is an exceptional event requiring CISO authorisation.
JIT (Just-in-Time) Access	A privileged access model where elevated permissions are activated for a specific session, for a defined time window, and automatically expire at the end of the window.
PAM Platform	Privileged Access Management platform — the approved tooling used to manage, vault, monitor, and record privileged sessions.
Privileged Account	Any account that holds administrative, root, superuser, system-level, or otherwise elevated permissions beyond those of a standard user.
Service Account	A non-human account used by an application, automated process, or integration to access systems, databases, or APIs.
Session Recording	The technical capture of the content and/or actions of a privileged session, retained for audit and forensic purposes.
Standing Privileged Access	A privileged account that is permanently active, without time-limiting or JIT controls. Prohibited for Tier 1 and GxP systems under this Policy.

— End of Document —

POL-009 v1.0 DRAFT | [Company Name] | SENSITIVE